

**LAPORAN KEAMANAN PERANGKAT LUNAK
KINARA PHARMA: SISTEM PENGELOLAAN STOK DAN
PENJUALAN OBAT**

Dosen Pengampu: AHMAD RIFA'I, S.Kom., M.Kom



Disusun Oleh:

M. ILHAM GHAZALI SIMARMATA	(2405027)
TSAABITA PARISYA MAULADI AZIZ	(2405054)
AI SITI NUR PAOJIAH	(2405044)

Tanggal pengumpulan : 11 Juni 2026

**JURUSAN TEKNIK INFORMATIKA
POLITEKNIK NEGERI INDRAMAYU**

2026

BAB I

PROFIL APLIKASI (*SSDLC & Threat Modeling*)

1.1 Deskripsi Singkat Aplikasi

Terlampir :  Proposal Proyek 2_Kelompok 9_D4RPL2A.pdf

1.2 Diagram Alur Aplikasi

Terlampir :  SRS_kelompok_9_KinaraPharma.pdf

1.3 Identifikasi Aset yang Perlu Dilindungi

Terlampir :  Dokumen SSP_Kelompok_9.pdf

1.4 Threat Modeling Sederhana Menggunakan Tabel STRIDE:

Komponen	Spoofing	Tampering	Repudiation	Info Disclosure	DoS	Elevation of Privilege
Modul Login & Otentikasi	✓	-	-	✓	✓	-
Modul Upload Resep	-	✓	-	✓	✓	-
Modul Order	-	✓	✓	-	✓	✓
Modul Kasir Offline	-	-	✓	-	-	-

Database & Pengelolaan Stok	—	✓	—	—	—	✓
--	---	---	---	---	---	---

1.5 Prioritas Keamanan

Analisis prioritas ancaman STRIDE beserta metodologi penilaian risikonya (seperti skor DREAD) telah dipaparkan secara rinci pada :

Laporan 01 :  Threat_Modeling_Kelompok 9_D4RPL2A.pdf

Laporan 02 :  Security_Requirements_Kelompok9.pdf

BAB II

ANALISIS OWASP TOP 10

2.1 Tabel Relevansi

Analisis OWASP Top 10 digunakan untuk melihat risiko keamanan yang paling relevan terhadap sistem Kinara Pharma :

Tabel 2.1 Tabel Relevansi

#	Kategori OWASP	Relevan?	Alasan Singkat
A01	Broken Access Control	✓ Ya	Sistem memiliki beberapa role (Admin, Staff, Pembeli) sehingga kontrol akses menjadi sangat penting.
A02	Cryptographic Failures	✓ Ya	Sistem menyimpan password pengguna dan token autentikasi yang harus dilindungi dengan hashing dan HTTPS.
A03	Injection	✓ Ya	Sistem menerima banyak input pengguna seperti login, pencarian obat, checkout, dan upload data ke database.
A04	Insecure Design	⚠ Perlu Dicek	Perlu memastikan fitur keamanan seperti rate limiting, validasi bisnis, dan proteksi brute force sudah dirancang dengan baik.
A05	Security Misconfiguration	✓ Ya	Konfigurasi server, Laravel, session, JWT, dan environment dapat menimbulkan risiko jika tidak diatur dengan benar.
A06	Vulnerable and Outdated Components	✓ Ya	Sistem menggunakan package pihak ketiga seperti Laravel, JWT Auth, Midtrans SDK, dan PhpSpreadsheet.
A07	Identification and Authentication Failures	✓ Ya	Sistem menggunakan login, reset password OTP, dan autentikasi JWT sehingga berhubungan langsung dengan proses identifikasi pengguna.
A08	Software and Data Integrity Failures	⚠ Perlu Dicek	Integritas data perlu dijaga terutama pada proses pembayaran Midtrans dan update data transaksi.
A09	Security Logging and Monitoring Failures	✓ Ya	Sistem mencatat aktivitas login dan logout sebagai bagian dari audit keamanan.
A10	Server-Side Request	✗ Tidak	Sistem tidak menyediakan fitur yang menerima

	Forgery	Relevan	URL eksternal dari pengguna untuk diproses server.
--	---------	---------	--

2.2 Deep Dive 3 Kategori Paling Relevan

1) A01 - Broken Access Control

Kategori ini sangat relevan karena Kinara Pharma memiliki tiga role utama, yaitu Pembeli, Staf, dan Admin. Setiap role memiliki hak akses berbeda. Pembeli hanya boleh mengakses profil, riwayat pesanan, resep, keranjang, dan notifikasi miliknya sendiri. Staf berfokus pada operasional seperti kelola obat, kelola stok, pesanan, kasir, dan validasi resep. Admin berfokus pada dashboard, laporan, data obat read-only, dan manajemen user.

2) A03 - Injection

Kategori Injection relevan karena sistem Kinara Pharma menerima banyak input dari pengguna, baik dari web maupun mobile. Input tersebut terdapat pada login, register, pencarian obat, filter kategori, checkout, update profil, input stok, laporan periode, dan upload resep. Jika input tidak divalidasi dengan benar, penyerang dapat mencoba memasukkan payload berbahaya seperti SQL Injection atau XSS. Mitigasi yang diterapkan adalah penggunaan Eloquent ORM dan Query Builder Laravel, validasi input menggunakan form request atau validator, pembatasan tipe data, dan tidak menyusun query SQL mentah dari input pengguna secara langsung. Dengan pendekatan ini, risiko SQL Injection dapat dikurangi karena parameter input diproses secara lebih aman.

3) A07 - Identification and Authentication Failures

Karena Kinara Pharma memiliki beberapa mekanisme autentikasi maka ini relevan. Website digunakan oleh Admin dan Staf dengan username dan password, sedangkan mobile digunakan oleh Pembeli dengan nomor HP dan password. Selain itu, sistem juga memiliki fitur reset password menggunakan OTP.

Risiko yang mungkin terjadi adalah brute force login, penyalahgunaan token, OTP flooding, atau penggunaan password lemah. Untuk mengurangi risiko tersebut, sistem menerapkan password hashing, token autentikasi JWT untuk mobile, session Laravel untuk web, pembatasan percobaan login, cooldown setelah beberapa kali gagal login, serta pencatatan aktivitas login berhasil dan gagal.

BAB III

3.1 Static Analysis (SAST)

Tools yang kami gunakan: **Larastan dan Psalm**

❖ **Output hasil scanning Larastan:**

```
PS C:\laragon\www\kinaraPharma> .\vendor\bin\phpstan analyse --memory-limit=2G
Note: Using configuration file C:\laragon\www\kinaraPharma\phpstan.neon.
36/36 [=====] 100%
```

[OK] No errors

```
❖❖ PS C:\laragon\www\kinaraPharma>
```

❖ **Output hasil scanning Psalm:**

```
PS C:\xampp\htdocs\KinaraPharma> ./vendor/bin/psalm
```

Running on PHP 8.4.19, Psalm 6.16.1@f1f5de594dc76faf8784e02d3dc4716c91c6f6ac.

```
JIT acceleration: OFF
You can enable JIT acceleration (experimental) with --force-jit.
```

```
Target PHP version: 8.2 (inferred from composer.json).
```

Scanning files...

3329 / 3329...

Analyzing files...

E

```
ERROR: NoEnvOutsideConfig - app/http/Controllers/Api/PaymentController.php:19:30 - env() called outside config directory. When config is cached, env() returns null. Use config() instead.
```

```
ERROR: NoEnvOutsideConfig - app/http/Controllers/Api/PaymentController.php:20:33 - env() called outside config directory. When config is cached, env() returns null. Use config() instead.
Config::$isProduction = env('MIDTRANS_IS_PRODUCTION', false);
```

```
ERROR: NoEnvOutsideConfig - app/Http/Controllers/Api/PaymentController.php:122:34 - env() called outside config directory. When config is cached, env() returns null. Use config() instead.
Config::$serverKey = env('MIDTRANS_SERVER_KEY');
```

```
ERROR: NoEnvOutsideConfig - app/http/Controllers/Api/PaymentController.php:123:37 - env() called outside config directory. When config is cached, env() returns null. Use config() instead.
Config::$isProduction = env('MIDTRANS_IS_PRODUCTION', false);
```

4 errors found

238 other issues found.

You can display them with `--show-info=true`

Psalm can automatically fix 116 of these issues.

Run Psalm again with

```
--alter --issues=MissingReturnType,ClassMustBeFinal,MissingParamType --dry-run
```

to see what it can fix.

Checks took 79.24 seconds and used 568.606MB of memory
Psalm was able to infer types for 90.6079% of the codebase

Tabel 3.1 Tabel Temuan

ID	File	Baris	Deskripsi Masalah	Tingkat Risiko
S-01	PaymentController.php	19	Pemanggilan <code>env()</code> diluar direktori konfigurasi. Saat konfigurasi Laravel di-cache, nilai dapat menjadi null sehingga berpotensi menyebabkan kegagalan autentikasi Midtrans.	Medium
S-02	PaymentController.php	20	Pemanggilan <code>env()</code> diluar direktori konfigurasi untuk mode produksi Midtrans. Risiko konfigurasi tidak terbaca ketika <code>config:cache</code> dijalankan.	Medium
S-03	PaymentController.php	122	Pemanggilan <code>env()</code> diluar direktori konfigurasi untuk <code>MIDTRANS_SERVER_KEY</code> . Dapat menyebabkan perilaku tidak konsisten pada lingkungan produksi.	Medium

Catatan: Psalm menemukan 4 error dengan jenis `NoEnvOutsideConfig`. Namun, terdapat 1 temuan pada file `PaymentController.php` baris 123 yang tidak dianggap sebagai kerentanan, karena berkaitan dengan konfigurasi `'MIDTRANS_IS_PRODUCTION = false'` yang memang disengaja diterapkan untuk penggunaan simulasi menggunakan Midtrans Sandbox. Jika nilai tersebut `'true'`, sistem akan terhubung ke lingkungan produksi midtrans, sehingga transaksi yang dilakukan akan menggunakan dana asli.

3.2 Dynamic Analysis (DAST) dengan OWASP ZAP

Automated Scan

This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'.

Please be aware that you should only attack applications that you have been specifically given permission to test.

URL to attack:

Scan Policy:

Use traditional spider: ☐

Use ajax spider: with

⚡ Attack
⏹ Stop

Bukti scan berjalan :

History Search Alerts Active Scan Output AJAX Spider				
New Scan Progress: 2: https://kelompok9.my.id 48%				
ID	Req. Timestamp	Resp. Timestamp	Method	URL
385	6/11/26, 4:02:02 AM	6/11/26, 4:02:03 AM	GET	https://kelompok9.my.id/js
386	6/11/26, 4:02:03 AM	6/11/26, 4:02:05 AM	GET	https://kelompok9.my.id/css
387	6/11/26, 4:02:05 AM	6/11/26, 4:02:06 AM	GET	https://kelompok9.my.id/images
388	6/11/26, 4:02:06 AM	6/11/26, 4:02:07 AM	GET	https://kelompok9.my.id/js
389	6/11/26, 4:02:07 AM	6/11/26, 4:02:08 AM	GET	https://kelompok9.my.id/css
390	6/11/26, 4:02:08 AM	6/11/26, 4:02:10 AM	GET	https://kelompok9.my.id/images
391	6/11/26, 4:02:07 AM	6/11/26, 4:02:10 AM	POST	https://kelompok9.my.id/

Hasil Scan ZAP :

Alerts (11)		Content Security Policy (CSP) Header Not Set
>	Content Security Policy (CSP) Header Not Set (3)	URL: https://kelompok9.my.id/
>	Cross-Domain Misconfiguration	Risk: Medium
>	Sub Resource Integrity Attribute Missing (3)	Confidence: High
>	Big Redirect Detected (Potential Sensitive Information Leak)	Parameter:
>	Cookie No HttpOnly Flag (3)	Attack:
>	Strict-Transport-Security Header Not Set (Systemic)	Evidence:
>	Timestamp Disclosure - Unix (Systemic)	CWE ID: 693
>	Information Disclosure - Suspicious Comments	WASC ID: 15
		Source: Passive (10038 - Content Security Policy (CSP) Header Not Set)
		Alert Reference: 10038-1

Tabel 3.2 Ringkasan Hasil ZAP Report

ID	Nama Temuan	Risiko	Endpoint yang Terdampak
D-01			
D-02			
D-03			

D-04			
------	--	--	--

BAB IV

MITIGASI & DEFENSE (*Defense in Depth*)

4.1 Tabel Mitigasi

Tabel 4.1 Tabel Mitigasi

ID Temuan	Masalah	Solusi Yang Diterapkan	Status

4.2 Pendekatan Defense in Depth

Pada aplikasi kinara Pharma menerapkan defense in depth atau pertahanan berlapis. Tujuannya agar jika satu pertahanan gagal masih ada pertahanan lain yang melindunginya.

1. Layer jaringan

Lapisan pertama pada tingkat jaringan. Aplikasi diakses menggunakan protokol HTTPS sehingga data yang dikirimkan antara pengguna dan server terenkripsi

2. Layer aplikasi

Pada lapisan ini aplikasi diterapkan autentikasi login untuk memastikan hanya pengguna yang terdaftar yang dapat mengakses sistem. Diterapkannya Role Based Access Control (RBAC) sehingga dapat mengakses fitur sesuai hak aksesnya masing masing. Setiap input dari pengguna juga di validasi untuk mengurangi resiko serangan seperti SQL Injection dan Cross-Site Scripting (XSS).

3. Layer Data

pada lapisan data, password pengguna tidak disimpan dalam bentuk teks biasa melainkan menggunakan hashing bcrypt. selain itu session pengguna diamankan menggunakan HttpOnly dan secure Cookie untuk mengurangi resiko pencurian session.

BAB V

REFLEKSI DAN KESIMPULAN

5.1 Apa yang paling mengejutkan saat melakukan security testing di aplikasi ini?

Hal yang paling mengejutkan bagi kami saat melakukan security testing adalah menyadari bahwa sebuah aplikasi yang terlihat berjalan dengan baik belum tentu aman. Kami memahami masih ada kemungkinan yang tidak terlihat secara langsung oleh pengguna tetapi dapat dimanfaatkan oleh pihak yang tidak bertanggung jawab. Kesalahan kecil dalam validasi data, pengaturan hak akses, atau pengelolaan akun dapat menimbulkan resiko yang cukup besar.

5.2 Apa yang paling sulit dipahami atau dikerjakan selama praktikum ?

Bagian yang sulit bagi kelompok kami adalah memahami cara mengidentifikasi ancaman resiko yang mungkin terjadi pada aplikasi, karena kami terbiasa berpikir sebagai pengembang yang berfokus pada pembuatan fitur saja. Ketika harus menganalisis kemungkinan serangan, kami membutuhkan waktu untuk memahami sudut pandang tersebut. Selain itu, konsep keamanan seperti threat modeling, identifikasi risiko, dan mitigasi ancaman cukup menantang karena membutuhkan pemahaman yang mendalam. Dan ternyata untuk penerapan keamanannya sangat rumit , karena kita sebagai developer harus menutup semua celah yang ada , sedangkan penyerang bisa masuk dari mana saja :(

5.3 Jika mengulangi dari awal, apa yang akan dilakukan berbeda sejak fase desain/ pengembangan?

Jika kami mengulang proyek ini dari awal, kami akan lebih memperhatikan aspek keamanan dari awal perancangan sistem. Kami menyadari bahwa keamanan seharusnya sudah dipikirkan sejak awal, bukan hanya saat aplikasi selesai dibuat. Kami juga akan lebih rutin melakukan pengujian secara bertahap, potensi masalah keamanan dapat ditemukan lebih cepat sehingga perbaikannya tidak terlalu sulit dan tidak memakan banyak biaya.

5.4 Apa satu pelajaran terpenting dari seluruh rangkaian materi ini ?

Pelajaran terpenting kami peroleh adalah bahwa aplikasi yang memiliki fitur lengkap dan dapat berjalan dengan baik tidak cukup, tetapi juga harus melindungi data serta resiko penyalahgunaan sistem. Melalui tugas ini kami menjadi lebih memahami bahwa keamanan bukanlah langkah tambahan yang dilakukan di akhir proyek, melainkan bagian yang perlu dipertimbangkan sejak awal pengembangan dan perancangan hingga aplikasi digunakan.

LAMPIRAN